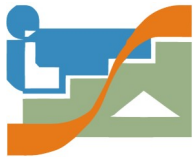




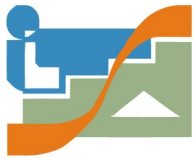
UNIT 02

Audit of Cybersecurity Incidents



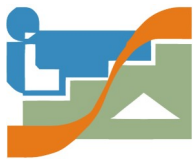


- **Taxonomy of cyber security incidents**
- **Controls and tools. Types and sources**
- **Detection of physical security incidents**
- **Controls through OSINT**
- **Classification, assessment, documentation, monitoring**



- **Taxonomy of cyber security incidents**
- **Controls and tools. Types and sources**
- **Detection of physical security incidents**
- **Controls through OSINT**
- **Classification, assessment, documentation, monitoring**

Taxonomy is the science that deals with classification, nomenclature and identification



Once again, we find information in the INCIBE, in:

«Guía nacional de notificación y gestión de ciberincidentes»

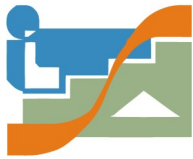
<https://www.incibe-cert.es/taxonomia>

- ♦ Abusive content
- ♦ Harmful content
- ♦ Obtaining information
- ♦ Intrusion attempt
- ♦ Intrusion
- ♦ Availability
- ♦ Information commitment
- ♦ Fraud
- ♦ Vulnerable
- ♦ others

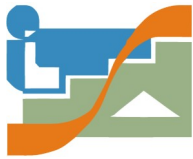


in accordance with
Guía Nacional de Notificación y
Gestión de Ciberincidentes

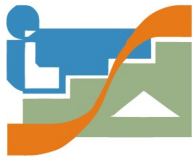
Ten groups



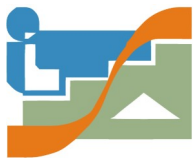
- ♦ Abusive content
 - ♦ SPAM
 - ♦ Hate crime
 - ♦ Child pornography, inappropriate sexual or violent content
- ♦ Harmful content
 - ♦ Infected system
 - ♦ C&C server
 - ♦ Malware distribution
 - ♦ Malware configuration
 - ♦ Domain generation algorithm
- ♦ Obtaining information
 - ♦ Scanning
 - ♦ Sniffing
 - ♦ Social engineering
- ♦ Intrusion attempt
 - ♦ Exploitation of known vulnerabilities
 - ♦ Access attempt with breach of credentials
 - ♦ Unknown attack



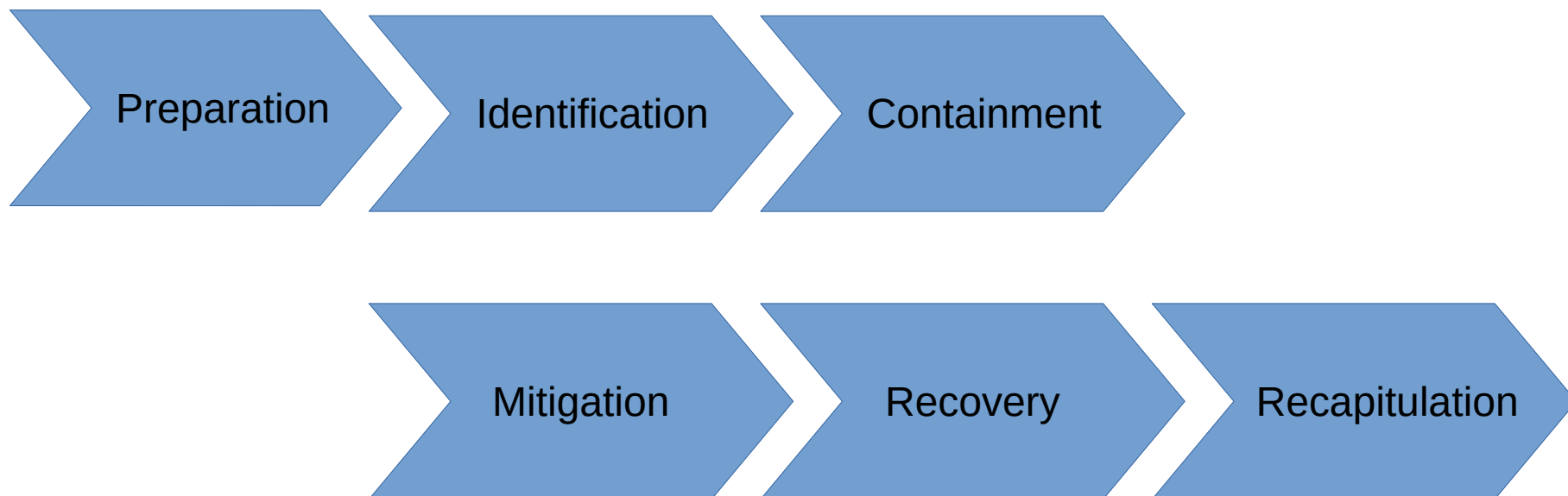
- Intrusion
 - Privileged Account Compromise
 - Unprivileged Account Compromise
 - App Engagement
 - Heist
- Availability
 - DoS
 - DdoS
 - sabotage
 - interruptions
- Information commitment
 - Unauthorized access to information
 - Unauthorized modification to information
 - Data loss

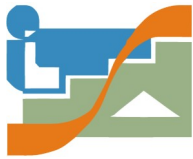


- ♦ Fraud
 - ♦ Unauthorized use of resources
 - ♦ Copyright
 - ♦ Impersonation
 - ♦ Phishing
- ♦ Vulnerable
 - ♦ Weak cryptography
 - ♦ DoS Amplifier
 - ♦ Services with potential unwanted access
 - ♦ Disclosure of information
 - ♦ Vulnerable system
- ♦ Others
 - ♦ Others
 - ♦ APT
 - ♦ Cyberterrorism
 - ♦ Computer damage PIC (critical infrastructure protection)

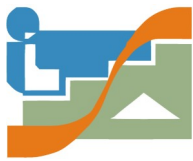


Life cycle of a "Cybersecurity Incident"





- Taxonomy of cyber security incidents
- **Controls and tools. Types and sources**
- Detection of physical security incidents
- Controls through OSINT
- Classification, assessment, documentation, monitoring



Monitoring --> IDS , IPS , SIEM

(Intrusion Detection System)

- It is an application used to detect unauthorized access to a computer or a network

(Intrusion Prevention System)

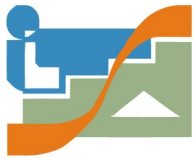
- It is software that is used to protect systems from attacks and intrusions

(Security Information and Event Management)

- It is a security system that seeks to provide companies with a quick and accurate response to detect and respond to any **threat** on their computer systems
- is a security solution that helps organizations recognize and address potential security threats and vulnerabilities before they have a chance to disrupt business operations

<https://www.incibe.es/protege-tu-empresa/blog/son-y-sirven-los-siem-ids-e-ips>

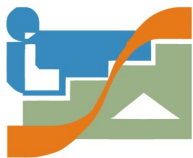
<https://www.a2secure.com/blog/ids-ips-hids-nips-siem-que-es-esto>



Monitoring --> IDS , IPS , SIEM

How does SIEM work?

At the most basic level, all SIEM solutions perform some level of data aggregation, consolidation and sorting functions in order to identify threats and adhere to data compliance requirements. While some solutions vary in capability, most offer the same core set of functionality



IDS , IPS

- Snort
- Suricata
- Bro
- OSSEC

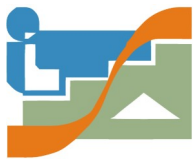


SIEM

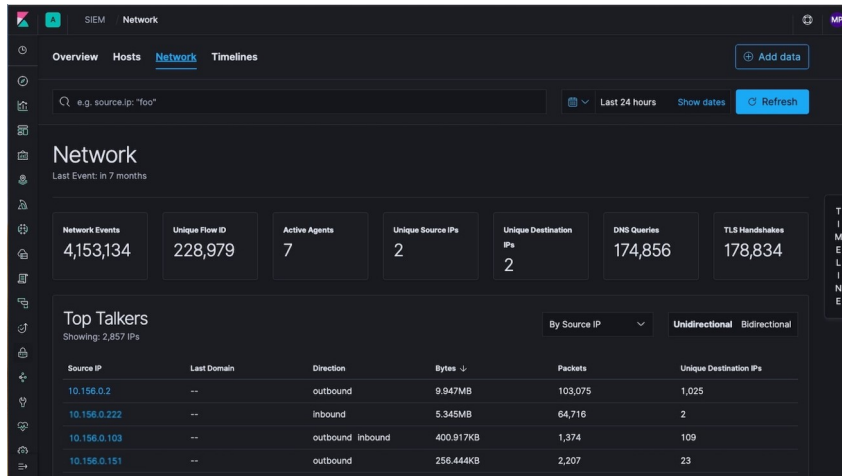
- Snorby
- Sguil
- Squert
- ELSA
- SPLUNK
- Elastic



incibe.es/ diseno-y-configuracion-de-ips-ids-y-siem-en-sci



SIEM examples



Monthly estimate

\$6,086

[See estimate details](#)

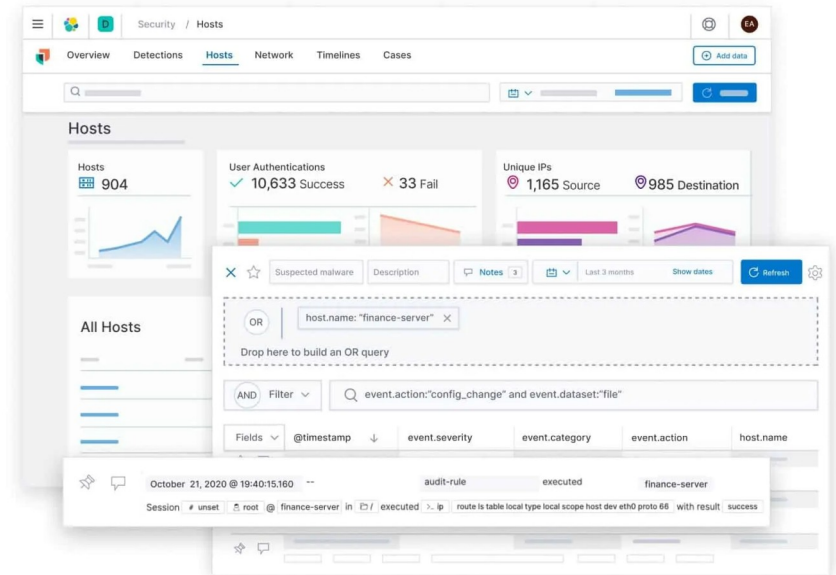
[Start free trial →](#)

Monthly estimate

\$94,631

[See estimate details](#)

[Start free trial →](#)

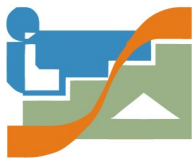


Pricing

Explore Splunk pricing options that align with your business needs. Our goal is to help you get more value from your data. Whether you need predictability or the flexibility to scale, you have options with Splunk.

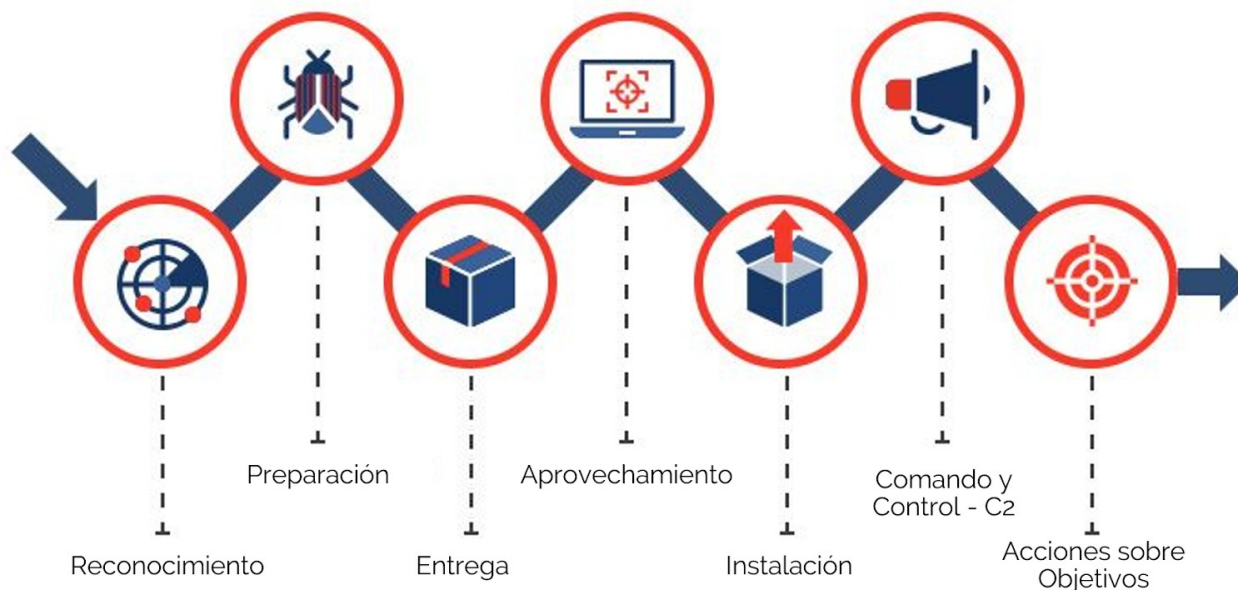
[Get an Estimate](#)



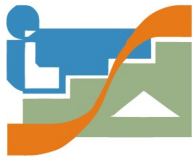


Ciber Kill Chain

It is a procedure developed by Lockheed Martin that divides the attack into seven distinct levels with the aim of being able to identify it and deal with it. This serves to help senior officials make strategic decisions to act against the computer attack.



como-usar-el-cyber-kill-chain-para-prevenir-un-ataque-a-tu-empresa



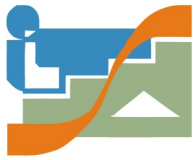
Other Tools

DLP Data Loss Prevention

Vulnerability Scanner

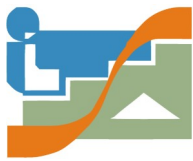
EPP Endpoint Protection Platform

ERD Endpoint Detection Response (EPP + IA)



Data sources:

- SO (Log records)
- Firewall (Logs of blocked connections)
- Proxy web (Records connections made)
- IDS / IPS
- SIEM (Alerts)
- DLP (Records)
- Antivirus -> EDR (Endpoint Detection & Response)
- Antispam
- NGFW (Next Generation FireWall)



Threat Intelligent Platform

It centralizes a collection of threat data from numerous sources and formats.

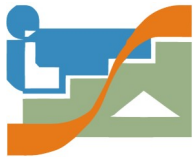
As the volume of data can be overwhelming, the platform is designed to aggregate the data in one place and present it in an understandable and usable format.

In other words, it helps organize the large volume of threat data you get from different sources into a single container

- Combine hundreds of sources of information in a single location.
- Receive and configure real-time alerts.
- Normalize the data you get. For example delete duplicates or define user rules (for example to prioritize some data sources)
- Integrate with other systems such as SIEMs, firewalls, incident response platforms...
- Create reports

https://es.wikipedia.org/wiki/Plataforma_de_inteligencia_contra_amenazas

<https://www.esecurityplanet.com/products/threat-intelligence-platforms/>



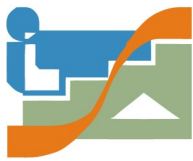
SOC - Security Operations Center

It refers to the team responsible for ensuring information security.

The SOC is a platform that allows the monitoring and administration of information system security through collection tools, event correlation and remote intervention. **The SIEM (Security Information Event Management) is the main tool of the SOC as it allows to manage the events of an IS.**

oracle.com/es/database/security/que-es-un-soc.html

checkpoint.com/cyber-hub/threat-prevention/what-is-soc/



SOC - Security Operations Center

<https://www.servicenow.com/es/products/security-operations/what-is-soc.html>

SOC benefits

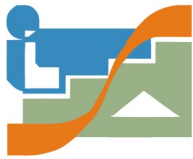
- * Minimum downtime
- * Improved customer confidence

SOC models

- * Dedicated or internal SOC
- * virtual SOC
- * SOC global or commando
- * Jointly managed SOC

How a
SOC
works



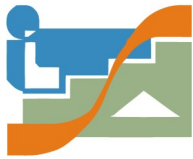


SOC - Security Operations Center

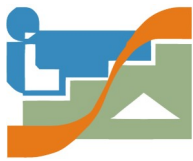
<https://www.servicenow.com/es/products/security-operations/what-is-soc.html>

SOC Roles

- * SOC manager
- * Incident response manager
- * Threat Hunter
- * Forensic investigator
- * SOC analyst and cyber security analyst



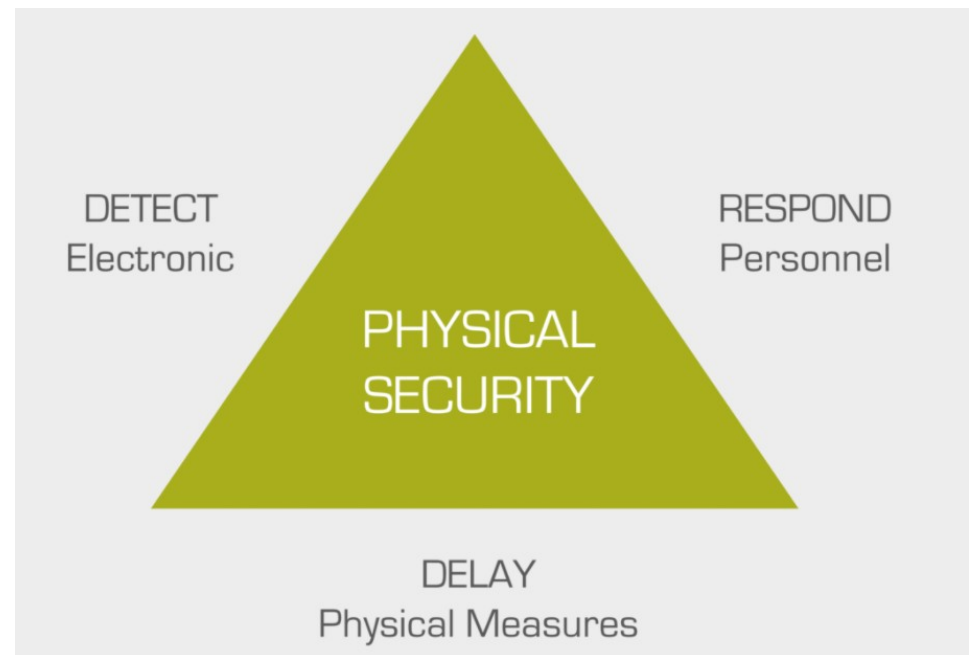
- Taxonomy of cyber security incidents
- Controls and tools. Types and sources
- **Detection of physical security incidents**
- Controls through OSINT
- Classification, assessment, documentation, monitoring



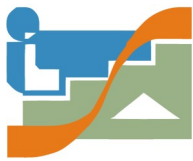
Detection of physical security incidents

- Climate / natural disasters
- Supply cut
- HW failures
- Human error
- Robbery
- Vandalism
- Sabotage
- Terrorism

Deterrence
(dissuasió)

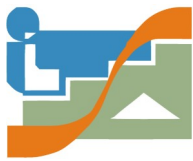


<https://www.osi.es/es/actualidad/blog/2020/08/21/protecciones-fisicas-evitar-riesgos-ciberseguridad>



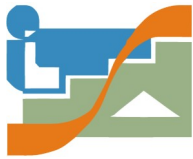
Top 5 Physical Security Risks

- **Threat 1: Tailgating**
 - Anti-tailgating doors & physical security training
- **Threat 2: Theft of documents**
 - Clear-desk policy, shred all sensitive documents
- **Threat 3: Unaccounted visitors**
 - All visitors are accounted for by supplying them with visitor passes.
- **Threat 4: Stolen identification**
 - Employees need to be educated on the importance of protecting their IDs or access cards.
- **Threat 5: Social engineering**
 - Train your staff

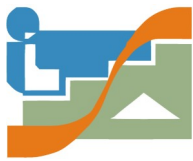


Physical Security Plan

- **Training:** Ensure your staff has the proper knowledge in implementing your physical security strategy.
- **Site design and layout:** Equipment and physical security components should be strategically placed to complement the design and layout of your facility.
- **Emergency response readiness:** Staff in your facility should be trained on what to do during certain situations and emergencies.
- **Access control:** Understand how you will assign access to your staff and limit access for restricted spaces.
- **Environmental components:** Create safety measures to mitigate damage from intentional or unforeseen natural disasters that may happen.
- **Surveillance Tools**



- Taxonomy of cyber security incidents
- Controls and tools. Types and sources
- Detection of physical security incidents
- **Controls through OSINT**
- Classification, assessment, documentation, monitoring

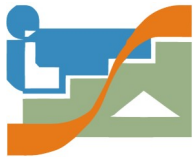


- **OSINT (Open Source INTelligence)**

Set of techniques and tools to collect **public information**, analyze the data and correlate them, turning them into useful knowledge.

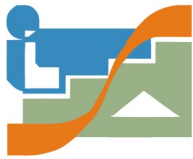
<https://www.incibe-cert.es/blog/osint-la-informacion-es-poder>





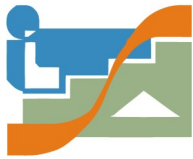
Public information

- **Publics records**
- **Media, images, videos**
- **Internet, Websites**
- **Social media platforms**
- **Government data**
- **Professional and academic publications**
- **Commercial data**
- **Gray literature (technical reports, patents, newsletters, ..)**
- **Public leaks**
- **Dark Web**



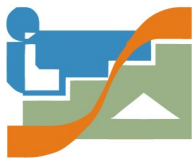
Who uses OSINT

- **Government**
- **Law Enforcement**
- **Military**
- **Investigative journalists**
- **Human rights investigators**
- **Private Investigators**
- **Law firms**
- **Information Security**
- **Cyber Threat Intelligence**
- **Pen Testers**
- **Social Engineers**



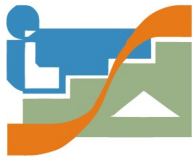
Passive vs Active OSINT

- **Passive OSINT**
 - **No engagement with the target**
 - **Passively collecting from publicly available information**
 - **Low risk of attribution**
- **Active OSINT**
 - **Engagement with the target**
 - **May require special permission**
 - **High risk of attribution**



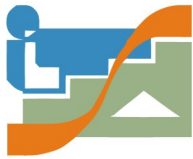
Common OSINT techniques

- **Search engines such as Google, Bing, and Yahoo**
- **Social media platforms such as Twitter, Facebook, and LinkedIn**
- **Public records such as court documents, property records, and business filings**
- **News sources such as newspapers, magazines, and online news**
- **Web scraping involves using software tools to extract data from websites**
- **Data analysis tools such as Excel, Tableau, and R**



Tools

- **Common Search Engines**
- **Specialized search engines**
- **Metadata collection tools**
- **Services to obtain information from a domain**
- **APIs of different services**
- **Other tools (kali, Intel Techniques)**
- **Palantir and Maltego**
- **Advanced tools: The Harvester, Recon-ng, DataSploit, Shodan, Paliscope**
- **Social engineering**

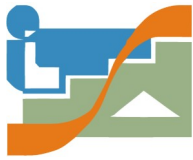


Other intelligence disciplines

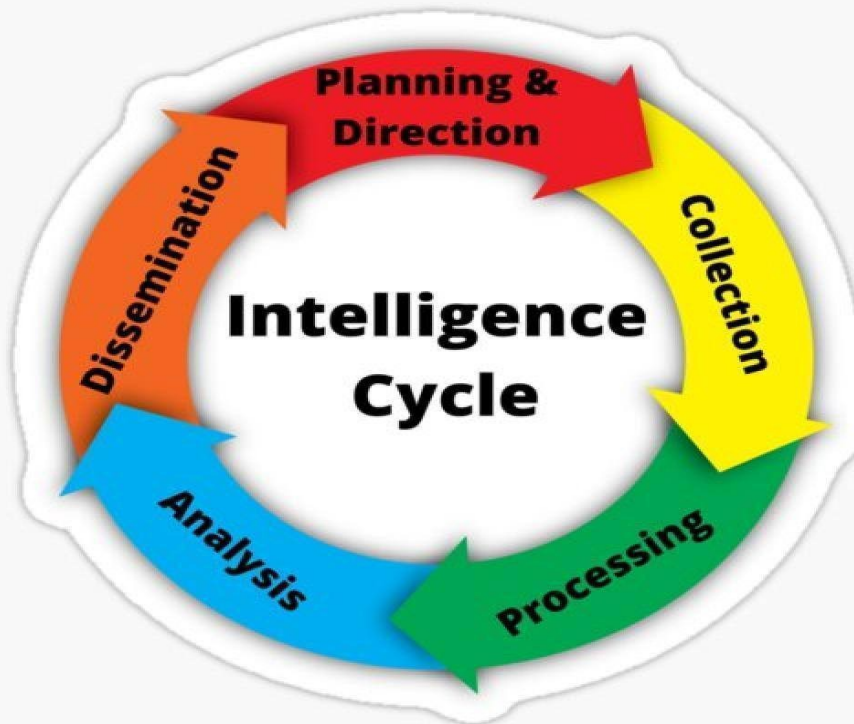
- **HUMINT** (Human intelligence)
- **SIGINT** (SIGNALS intelligence)
- **IMINT** (Images intelligence)
- **MASINT** (Measurement and signature intelligence)
- **GEOINT** (Geospatial intelligence)
- **FININT** (Financial intelligence)
- ...

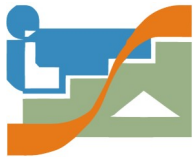


GIAC Open Source Intelligence Certification (GOSI)



Intelligence Cycle

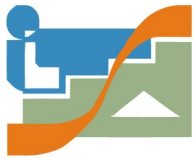




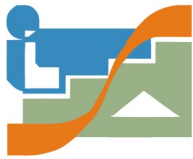
Disinformation in Cyberspace

FAKE NEWS

- <https://www.ccn-cert.cni.es/es/informes/informes-de-buenas-practicas-bp/3549-ccn-cert-bp-13-desinformacion-en-el-ciberespacio/file?format=html>

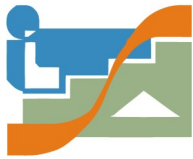


- Taxonomy of cyber security incidents
- Controls and tools. Types and sources
- Detection of physical security incidents
- Controls through OSINT
- **Classification, assessment, documentation, monitoring**



Classification

- **Unauthorized access**
- **Unauthorized resource modification**
- **Inappropriate use of resources**
- **Non-availability of resources**
- **Multicomponent**
- **others**



• Evaluation

- High impact
- Medium Impact
- Low Impact

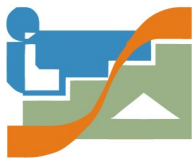


framework mitre-att&ck

• Prioritization

- Criticality
- Current impact
- Future impact

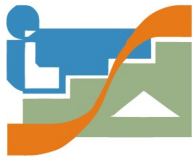




- Documentation (Lessons Learned)

- Initial follow-up





Record of lessons learned -> will allow you to know..

- **Exactly what happened, when and how the staff handled the incident.**
- **The documented procedures.**
- **If measures or actions were taken that could have prevented the recovery.**
- **What would be the personnel management and what should be done the next time a similar incident occurs.**
- **Corrective actions can prevent similar incidents in the future.**
- **What additional tools or resources are needed to detect, analyze and mitigate incidents in the future.**

incibe.es/incibe-cert/blog/buenas-practicas-lecciones-aprendidas-en-la-identificacion-de-amenazas-y-respuesta